

LAPORAN SESI TANYA JAWAB

TUGAS FINAL KEAMANAN DATA DAN JARINGAN 2026

Kelompok Penyaji: Kelompok 6

Anggota:

- a. RR Divana Widyacikha Kharisma (2350231001)**
- b. Raisa Dastria Tiananda (2350231017)**

Kelompok Penanya

1. Kelompok 11

Anggota:

- a. M Gizka Naufal Rizkullah
- b. Dhirgam Hanif F
- c. Khaerul Mutakin

2. Kelompok 18

Anggota:

- a. Kirana Novita
- b. Nayla Putri Romdoni
- c. Meila Fitri

Sesi Tanya Jawab

1. Sesi Tanya Jawab dengan Kelompok 11

a. Pertanyaan:

Apa dampak yang dapat terjadi jika celah SQL Injection pada aplikasi web tidak segera diperbaiki?

b. Skor Pertanyaan adalah:

Pertanyaan ini berbobot 5/10 karena tidak hanya meminta definisi mengenai SQL Injection, tetapi juga mengharuskan kelompok memahami konsekuensi nyata yang dapat ditimbulkan apabila kerentanan tersebut dibiarkan. Untuk menjawabnya dengan baik, kelompok perlu menghubungkan aspek teknis dengan dampak bisnis, seperti kebocoran data, manipulasi atau penghapusan data, pengambilalihan akun,

gangguan operasional, kerugian finansial, hingga penurunan reputasi perusahaan. Oleh karena itu, pertanyaan ini menuntut pemahaman yang lebih luas mengenai implikasi keamanan informasi, bukan sekadar hafalan konsep dasar SQL Injection.

c. Jawaban Kelompok Saya (Penyaji):

Berdasarkan hasil pengujian, jika celah SQL Injection tidak segera diperbaiki, penyerang dapat mengekstrak data sensitif pengguna seperti email, alamat, nomor telepon, role, dan hash password. Selain itu, penyerang juga dapat memperoleh informasi struktur database dan server untuk melakukan serangan lanjutan. Ditemukannya akun dengan role admin berpotensi menyebabkan eskalasi hak akses dan pengambilalihan sistem. Meskipun password tersimpan dalam bentuk hash, password tersebut masih dapat di-crack jika lemah. Oleh karena itu, SQL Injection dapat menyebabkan kebocoran data, pencurian identitas, phishing, account takeover, hingga penguasaan sistem secara keseluruhan

d. Tanggapan hasil penanya:

Tadi disebutkan password masih berupa hash dan bisa di-crack jika lemah. Menurut kelompok kalian, apakah penggunaan hash saja sudah cukup untuk melindungi password? Mengapa?

e. Jawaban balik kelompok saya:

Berdasarkan hasil pengujian, penggunaan hash saja belum cukup untuk melindungi password sepenuhnya. Meskipun password disimpan dalam bentuk hash bcrypt dan tidak dapat langsung dibaca, hash tersebut masih bisa di-crack menggunakan tools seperti John the Ripper atau Hashcat, terutama jika pengguna menggunakan password yang lemah atau umum. Karena itu, jika terjadi kebocoran database, password tetap berisiko diketahui oleh penyerang. Oleh sebab itu, selain menggunakan hashing, pengguna juga perlu menggunakan password yang kuat agar lebih sulit dipecahkan

f. Jawaban kelompok 11:

Pertanyaan kelompok kami sudah merasa terpenuhi dan setuju menutup sesi pertanyaan

2. Sesi Tanya Jawab dengan Kelompok 18

a. Pertanyaan:

Pada saat demo manual, ditunjukkan bahwa penyerang bisa melakukan bypass authentication dan langsung masuk ke halaman admin menggunakan kode ' OR 1=1 -- -. Jika source code aplikasi toko online tersebut sudah kalian patch menggunakan Prepared Statements, apa yang akan terjadi di layar browser jika kode tersebut dimasukkan kembali? Jelaskan mengapa hal itu bisa terjadi?

b. Skor Pertanyaan adalah:

Pertanyaan ini berbobot 8/10, ini tergolong cukup sulit karena tidak hanya menanyakan konsep dasar SQL Injection, tetapi juga menguji pemahaman kelompok mengenai mekanisme mitigasi menggunakan Prepared Statements. Untuk menjawabnya, mereka harus mampu menjelaskan perubahan perilaku aplikasi setelah dilakukan perbaikan, memprediksi hasil yang muncul pada browser, serta memahami alasan teknis mengapa payload ' OR 1=1 -- - tidak lagi dapat memanipulasi query SQL. Dengan kata lain, pertanyaan ini menuntut pemahaman menyeluruh mulai dari proses eksploitasi, cara kerja query yang rentan, hingga mekanisme pertahanan yang diterapkan setelah patch dilakukan

c. Jawaban Kelompok Saya (Penyaji):

Jika aplikasi sudah di-patch menggunakan Prepared Statement, maka payload ' OR 1=1 -- - tidak akan bisa digunakan untuk bypass authentication. Pengguna akan tetap gagal login dan browser akan menampilkan pesan seperti "Akun dengan email tersebut tidak ditemukan" atau "Password salah". Hal ini karena input tersebut diperlakukan sebagai teks biasa, bukan sebagai perintah SQL. Selain itu, sistem juga sudah melakukan verifikasi password, sehingga login hanya berhasil jika email dan password yang dimasukkan benar.

d. Jawaban kelompok 11:

Pertanyaan kelompok kami sudah merasa terpenuhi dan setuju menutup sesi pertanyaan